

OWASP Algiers Chapter | Advancing Application Security

Committed to improving software security through community-driven projects, education, and collaboration.



Contact: Algiers-Leaders@owasp.org | owasp.org/www-chapter-algiers

OWASP Algiers Chapter     

OWASP Top 10

...but for Operational Technology?!

Release 1.0 (October 2025)

Who Am I



Mehdi Nacer KERKAR, a Consultant with over half a decade of experience in multiple industries in EMEA region.

With a CISO vision, I assess & develop cybersecurity programs across the Information Security world.

Mehdi Nacer KERKAR

IT/OT Cybersecurity Consultant | Instructor & Mentor

- Cyber Security Manager Lead @ PwC Algeria
- Guest Lecturer @ HIS University المعهد العالي للعلوم
- Member @ OWASP Algiers Chapter
- Founder Member & Membership Director @ CSA Algeria
- Mentor @ TAP Talent Acceleration Platform
- OWASP, CSA, ISC2, ISA Global Member



Agenda

1. **What is OWASP?** – What is this ?
2. **What is OT?** - Understanding the basics
3. **IT vs. OT** - Why safety is #1
4. **The Architecture** - The Purdue Model
5. **The Top 10 Risks** - Deep dive into vulnerabilities
6. **Action Plan** - How to secure the future



What is OWASP?

Open Worldwide Application Security Project

- Open community aiming to increase software security.
- Provides free tools and documentation.
- Famous for "OWASP Top 10" (Web Apps).
- It's testing guides ASVS, MASVS



Famous Tools

- OWASP ZAP (Zed Attack Proxy)
- JuiceShop (Vulnerable App for Training)

What is Operational Technology (OT)?

Definition

Hardware and software that detects or causes a change through the direct monitoring and/or control of physical devices, processes, and events.



What is Operational Technology (OT)?



Defining Operational Technology (OT)



Hardware & Software

OT consists of systems that monitor and control physical processes in real-time.

Unlike IT, which manages **data**, OT manages **physics**.



Common Examples

- SCADA (Supervisory Control and Data Acquisition)
- PLCs (Programmable Logic Controllers)
- DCS (Distributed Control Systems)
- Industrial Robotics, Sensors & Actuators

OT vs. IT security

OT vs. IT: Characteristics

OT system characteristics differ fundamentally from traditional IT systems.

IT Priorities (CIA)

1. Confidentiality
2. Integrity
3. Availability

OT Priorities (AIC)

1. **Availability** (Keep it running)
2. **Safety** (Don't hurt anyone)
3. Integrity
4. Confidentiality

The Consequences: Safety & Life

IT Security Failure

In a standard IT environment, a breach usually results in data loss, financial theft, or reputation damage.

\$\$\$

OT Security Failure

In OT, a breach can cause physical damage, environmental disasters, injury, or even loss of life.

! DANGER

IT vs. OT: Two Worlds

Feature	IT (Information Tech)	OT (Operational Tech)
Primary Goal	Confidentiality, Integrity, Availability	Availability, Safety , Integrity
Lifespan	3-5 Years	15-20+ Years
Patching	Frequent, Automated	Rare, Planned Downtime
OS	Latest Windows/Linux	Legacy (XP, Win 7), RTOS

The Purdue Model

The Purdue Model (ISA-95)

**IT Network
Level 4-5**

**OT Network
Level 0-3**

Mapping the Factory

The Purdue Model is the industry standard for segmenting industrial networks. It separates the business network (Enterprise) from the critical control network (OT).

Key Takeaway: Proper segmentation is the #1 defense against OT attacks.

Purdue Levels 5 & 4: The Enterprise



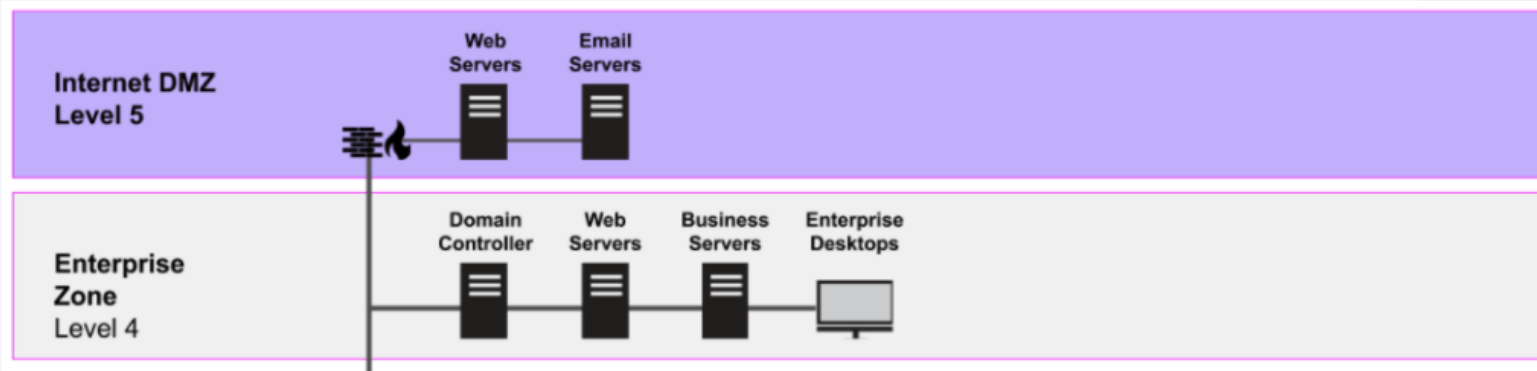
Level 5: Enterprise

The corporate network. Internet access, email servers, HR systems. This is the most exposed layer.



Level 4: Business Logistics

Manages production schedules. ERP (Enterprise Resource Planning) systems. The bridge between sales orders and the factory floor.



Purdue Levels 3 & 2: Control Zone



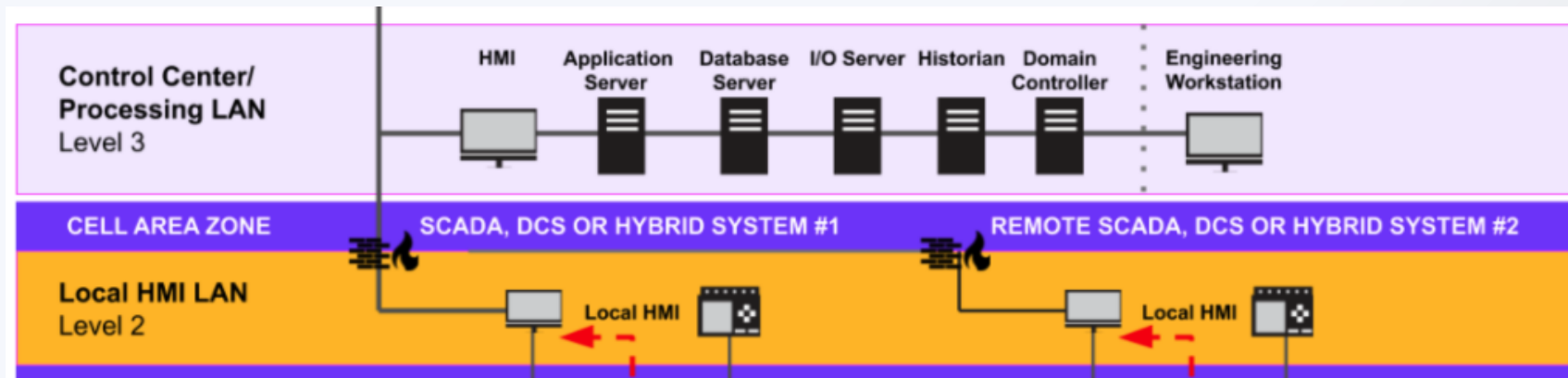
Level 3: Operations

Engineering workstations, Historians (databases for process data), and centralized Control Rooms.



Level 2: Supervisory

HMIs (Human Machine Interfaces) and SCADA servers. This is where operators touch screens to open valves or start motors.



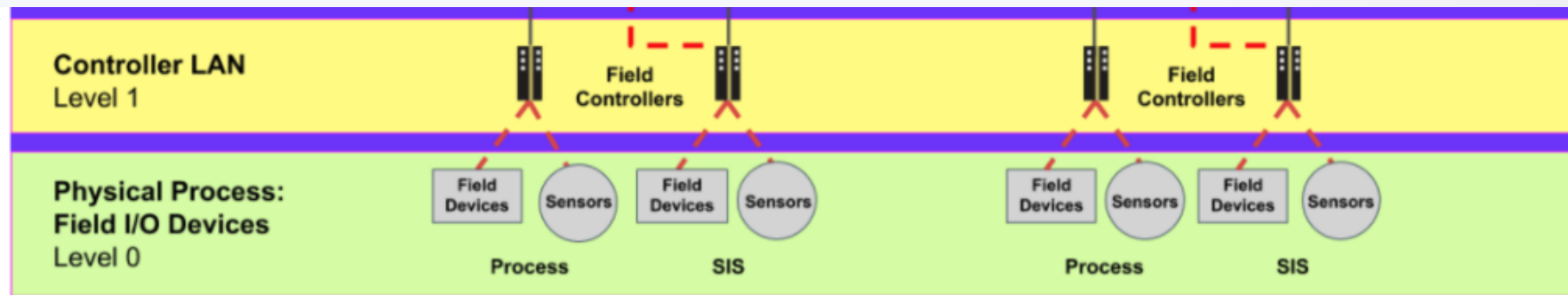
Purdue Levels 1 & 0: The Physical Zone

Level 1: Basic Control

PLCs (Programmable Logic Controllers). Rugged computers that read inputs and drive outputs. They run the logic.

Level 0: The Process

Motors, pumps, sensors, robotic arms. The actual physical equipment doing the work.



History of OT Cyber Attacks (Part 1)

Year	Attack/Malware	Impact
2008	Agent.bz	US Military breach (USB)
2010	Stuxnet	Centrifuge destruction (Iran)
2011	Night Dragon	Energy sector espionage
2014	Havex	Energy sector reconnaissance
2015	BlackEnergy	Ukraine Power Grid Outage

History of OT Cyber Attacks (Part 2)

Year	Attack/Malware	Impact
2017	TRITON / TRISIS	Targeted Safety Systems (SIS)
2019	LockerGoga	Manufacturing (Norsk Hydro)
2020	SolarWinds	Supply Chain Compromise
2021	Colonial Pipeline	Gas Pipeline Shutdown
2022	Industroyer2	Failed attack on Ukraine Grid
2023	Israel Water	Irrigation Systems Attacked
2024	RansomHub	Targeting Critical Infra

The Lifecycle Challenge

IT Lifecycle

2-4 Years

Systems are replaced frequently. Security is baked into new OS versions.

OT Lifecycle

1-3 Decades

What security mechanisms did we have 30 years ago? Many legacy devices are still in production.

Legacy Protocols

Insecure by Design

Industrial protocols (Modbus, DNP3, Ethernet/IP) were designed for trust, not security.

- No Authentication
- No Encryption (Plain Text)
- No Integrity Checks



Supply Chain Constraints

- **Complex Ecosystem:** Asset Owners, Integrators, and Vendors.
- **Vendor Lock-in:** Only a few manufacturers exist for specialized equipment.
- **Rigid SLAs:** "If you install antivirus, you void the warranty." Service Level Agreements often deny security changes.

The Problem: Blast Radius

Consequences of Failure

Because devices are hard to patch and have long lifecycles, a single breach can have a massive impact.

- Network Segmentation is crucial.
- Physical Access Control is mandatory.



Why an OT Top 10?

"The traditional OWASP Top 10 focuses on web apps. But SQL Injection doesn't blow up a pipeline. We needed a list that addresses **Systemic Risks** in the physical world."

Introducing: OWASP OT Top 10

The Mission

To provide a prioritized list of the most critical risks in Operational Technology.



Methodology

Data Sources

- ENISA Threat Landscape 2024
- Critical Infrastructure Sector Reports
- Vendor Threat Reports (Dragos, Nozomi, etc.)
- Pentest Census (Limes Security)
- Analysis Reports (OMICRON Energy)

Contributors

A living project with experts from various fields:

OT Pen-Testers

Security Architects

Incident Responders

Academic Researchers

OT Vulnerability Researchers

The List (2025 Release)

- **1.** Unknown Assets & Unmanaged Access
- **2.** Devices with Known Vulnerabilities
- **3.** Inadequate Supply Chain Management
- **4.** Loss of Availability
- **5.** Insufficient Access Control

- **6.** Missing Incident Detection
- **7.** Broken Zones & Conduits Design
- **8.** Missing Awareness
- **9.** Insecure Components/Protocols
- **10.** Missing Hardening

1. Unknown Assets & External Access

The Ghost in the Machine

You cannot secure what you don't know exists. A major risk is "Shadow OT"—devices connected by engineers for convenience (like a Wi-Fi access point) that are not in the inventory.

Impact: Attackers find these unmonitored backdoors to bypass firewalls entirely.



Mitigation: Inventory is King



Passive Scanning

Use passive network monitors to listen to traffic and build an asset map without disrupting operations.



NAC

Network Access Control.
Ensure that if a new MAC address plugs in, the port shuts down automatically.



Walkdowns

Physically inspect cabinets.
Look for rogue modems or USB devices.

2. Devices with Known Vulnerabilities

Patching Paralysis

OT devices run for decades. Many PLCs in use today have vulnerabilities discovered 5 years ago, but patching requires shutting down the factory.

Impact: Publicly available exploit scripts (Metasploit) can be used by low-skill attackers to take control.



Mitigation: Virtual Patching



Virtual Patching

Use an IPS (Intrusion Prevention System) rule to block the specific exploit packet before it reaches the vulnerable PLC.



Isolation

If you can't patch it, put it in a strict firewall zone where only one trusted server can talk to it.



Planned Outages

Schedule upgrades during annual maintenance windows.

3. Inadequate Supply Chain Management

Inherited Risks

OT relies on integrators and vendors. If your vendor's software update server is hacked (like SolarWinds), your secure factory gets infected via a "trusted" update.

Also includes buying hardware with pre-installed malware.



Mitigation: Trust but Verify



SBOM

Require a Software Bill of Materials. Know exactly what libraries are inside the software you buy.



Secure Laptops

Scan vendor laptops before allowing them to connect to your ICS network for maintenance.



Offline Updates

Download updates to a quarantined sandbox first. Test them before moving to the production network.

4. Loss of Availability

The OT Prime Directive Failure

In OT, availability is everything. Ransomware is the biggest threat here—locking up the HMIs or Engineering Workstations so operators are blind.

Impact: Loss of production, financial ruin, or blind operation leading to accidents.



Mitigation: Resilience



Redundancy

Have hot-standby controllers and redundant network paths. If one fails, the other takes over instantly.



Offline Backups

Keep backups of PLC logic and HMI configs completely offline (air-gapped) so ransomware can't touch them.



Manual Mode

Train operators to run the plant manually if the computers go dark.

5. Insufficient Access Control

Everyone is Admin

Many OT systems use shared generic accounts like "Operator" or "Admin" with passwords taped to the monitor. Everyone has full rights to change setpoints.



Mitigation: Least Privilege



Individual Accounts

Stop sharing passwords.
Every operator gets their own login to trace actions.



MFA

Multi-Factor Authentication is mandatory for any remote access (VPN).



Role-Based Access

Operators can only operate.
Engineers can only program.
Limit the damage a compromised account can do.

6. Missing Incident Detection

Flying Blind

Attacks are rarely instant. Hackers often lurk in the network for months. If you aren't logging or monitoring OT traffic, you won't know you're owned until the factory stops.



Mitigation: Visibility



OT-Specific IDS

Use Intrusion Detection Systems that understand industrial protocols (e.g., Nozomi, Dragos, Claroty). They alert on "Stop CPU" commands or firmware uploads.



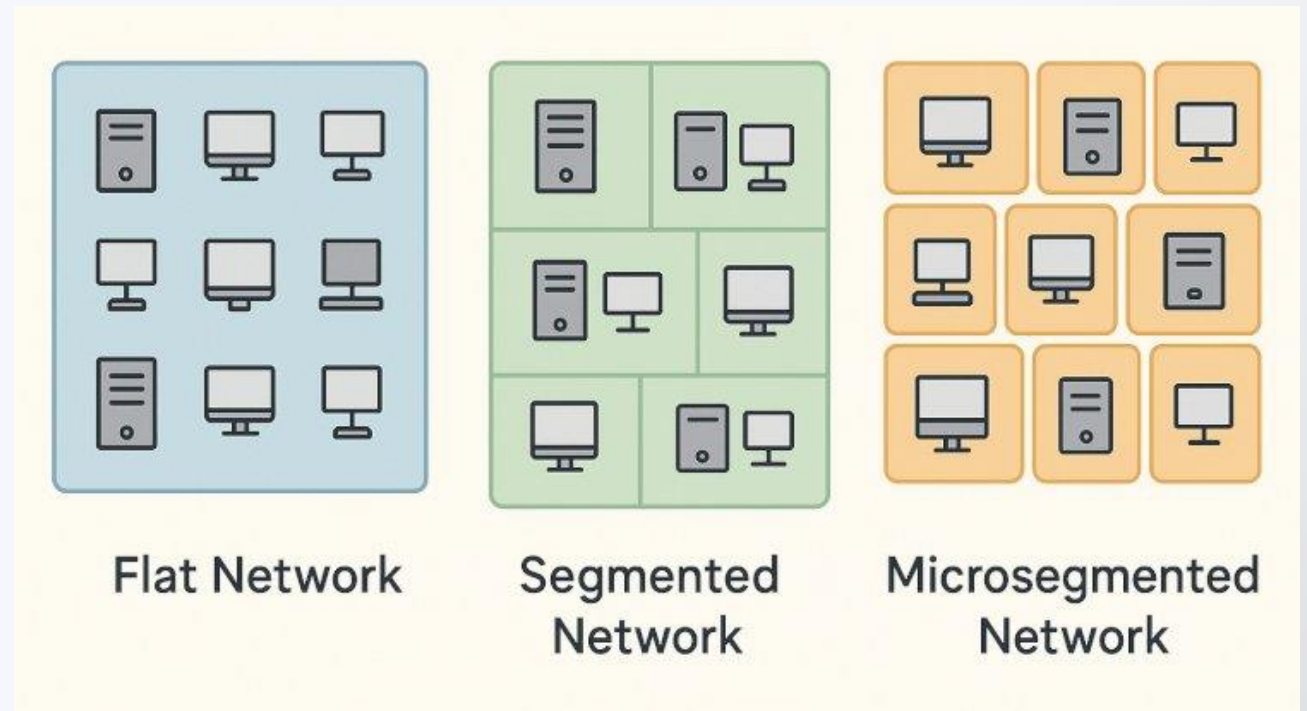
Incident Playbooks

Have a plan. If an alert fires, who do you call? Do you disconnect the safety system? Practice these drills.

7. Broken Zones & Conduits

Flat Networks

A "flat" network allows a virus on a receptionist's PC to spread directly to a PLC on the factory floor. Poor segmentation is the primary enabler of ransomware in OT.



Mitigation: The DMZ



Industrial DMZ

Create a buffer zone between IT and OT. No direct traffic is allowed. Everything must terminate in the DMZ (jump server).



Conduits

Group critical assets into "Zones" and force all traffic through a "Conduit" (Firewall) with strict rules.



Whitelisting

OT traffic is predictable. Deny everything, and only allow the specific conversations required for the process.

8. Missing Awareness

The Human Factor

OT engineers are brilliant at process control but may click phishing links or plug in found USB drives.

Cybersecurity is often seen as a hindrance to production.



Mitigation: Culture Change



Contextual Training

Don't just use generic IT training. Show examples of a PLC blast furnace explosion caused by a cyberattack. Make it relevant to safety.



USB Sanitation Stations

Provide kiosks where USB drives can be scanned for viruses before being plugged into the control network.

9. Insecure Components/Protocols



Insecure by Design

Protocols like Modbus and DNP3 were designed in the 70s. They have **no encryption** and **no authentication**.

Anyone on the network can send a "Stop" command, and the PLC will obey without asking "Who are you?".

Mitigation: Wrap & Protect



VPN Tunnels

Wrap insecure protocols inside encrypted VPN tunnels (IPsec) when communicating between sites.



Deep Packet Inspection

Use firewalls that can read Modbus. Create rules like: "HMI can Read, but only Engineering Station can Write."



Upgrade

Migrate to secure versions like DNP3 Secure Authentication (SA) or IEC 62351 where possible.

10. Missing Hardening

Default is Dangerous

This isn't a bug; it's laziness. Devices are deployed with default passwords (admin/admin), unused ports enabled, and unnecessary services (web servers, telnet) running.

This expands the attack surface unnecessarily.



Mitigation: Baseline & Harden



Disable Unused Services

If a PLC doesn't need a web server, turn it off. Close port 80. Close Telnet.



Change Defaults

Mandatory policy: No device goes into production with a default password.



Golden Images

Create a secure "Golden Image" configuration. Deploy this standard to all new devices.

Summary

- Focus on **Safety & Availability** (not just security).
- Devices are hard to patch and have long lifecycles.
- Only a few vendors dominate the market.
- **Leads to:** High need for segmentation and compensation.

Secure the Future

Operational Technology is the backbone of modern society.

By understanding these **Top 10 Risks**, you are taking the first step in defending our critical infrastructure.

Questions?

Thank You!

Questions?



Connect with me



Star the repo

